

Microsoft Thread Modelling Tool/Оценка риска с CVE

Литература

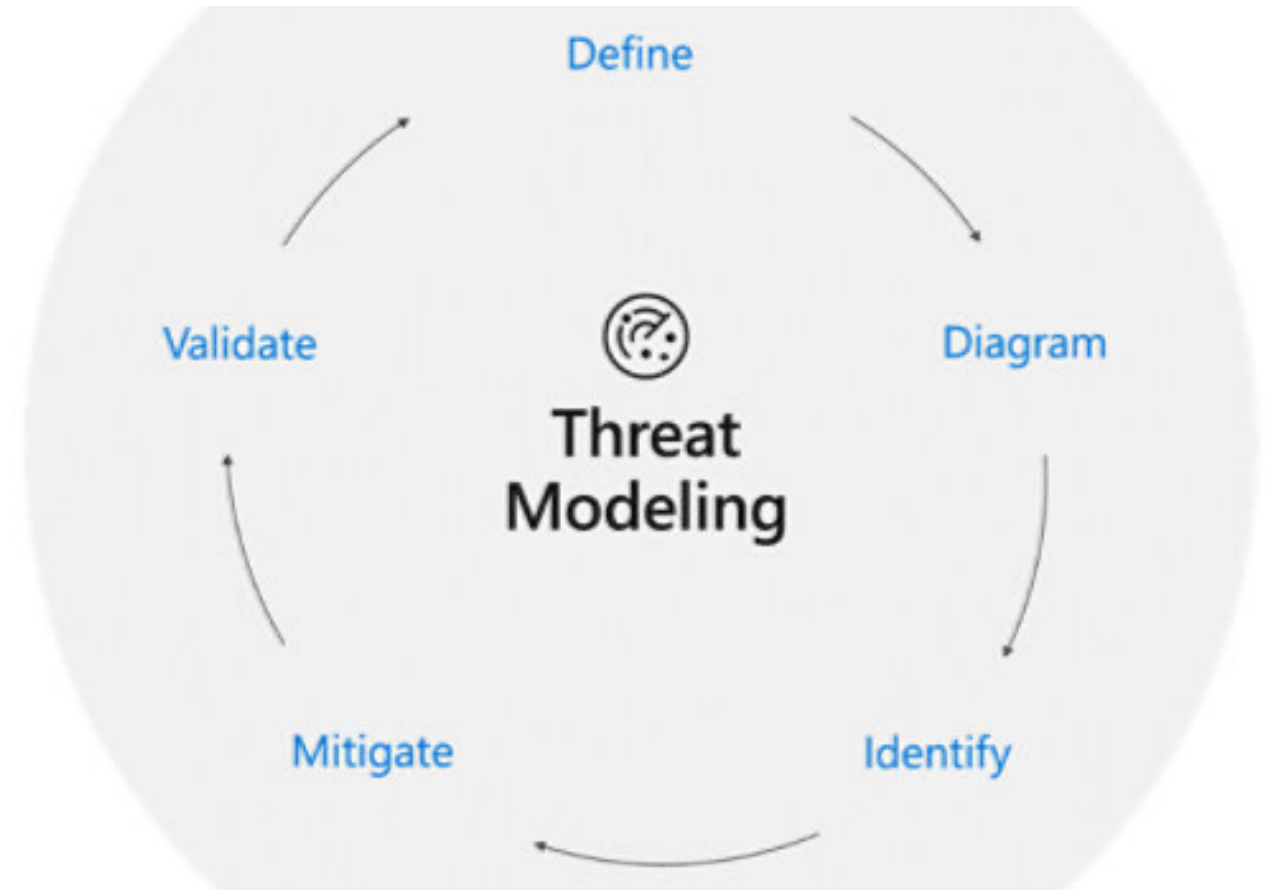
- **Начало работы со средством моделирования угроз (Microsoft Thread Modeling Tool)** <https://learn.microsoft.com/ru-ru/azure/security/develop/threat-modeling-tool-getting-started>
- Методика оценки угроз ФСТЭК
- Стандарт ИСО 27005 оценка риска
- Anne Honkaranta, Tiina Leppänen, and Andrei Costin. 2021. Towards practical cybersecurity mapping of stride and cwe—a multi-perspective approach. In 2021 29th Conference of Open Innovations Association (FRUCT). IEEE, 150–159.
- M Loveless. 2008. CWE mapping analysis. https://cwe.mitre.org/documents/mapping_analysis/index.html [доступ 10-Января-2025]

MTMT и жизненный цикл объекта

Моделирование угроз включает пять основных этапов:

- Определение требований безопасности
- Создание диаграммы приложения.
- Выявление угроз
- Снижение угроз
- Проверка того, что угрозы были устранены

Моделирование угроз должно быть частью жизненного цикла разработк позволяя постепенно совершенствове модель угроз объекта



Вспоминаем: Stride (Microsoft)

[https://learn.microsoft.com/en-us/previous-versions/commerce server/ee823878\(v=cs.20\)?redirectedfrom=MSDN](https://learn.microsoft.com/en-us/previous-versions/commerce server/ee823878(v=cs.20)?redirectedfrom=MSDN)

- Подмена личности (**Spoofing** identity)
- Подделка данных (**Tampering** with data)
- Угрозы отказа в совершении действия (**Repudiation** threats)
- Раскрытие информации (**Information** disclosure)
- Отказ в обслуживании (**Denial** of service)
- Повышение привилегий (**Elevation** of privileges)

Stencils (Трафареты)

Stencil name	Details
Process	Applications, browser plug-ins, threads, virtual machines
External interactor	Authentication providers, browsers, users, web applications
Data store	Cache, storage, configuration files, databases, registry
Data flow	Binary, ALPC, HTTP, HTTPS/TLS/SSL, IOCTL, IPsec, named pipe, RPC/DCOM, SMB, UDP
Trust line/Border boundary	Corporate networks, internet, machine, sandbox, user/kernel mode

Stencils (Трафареты)

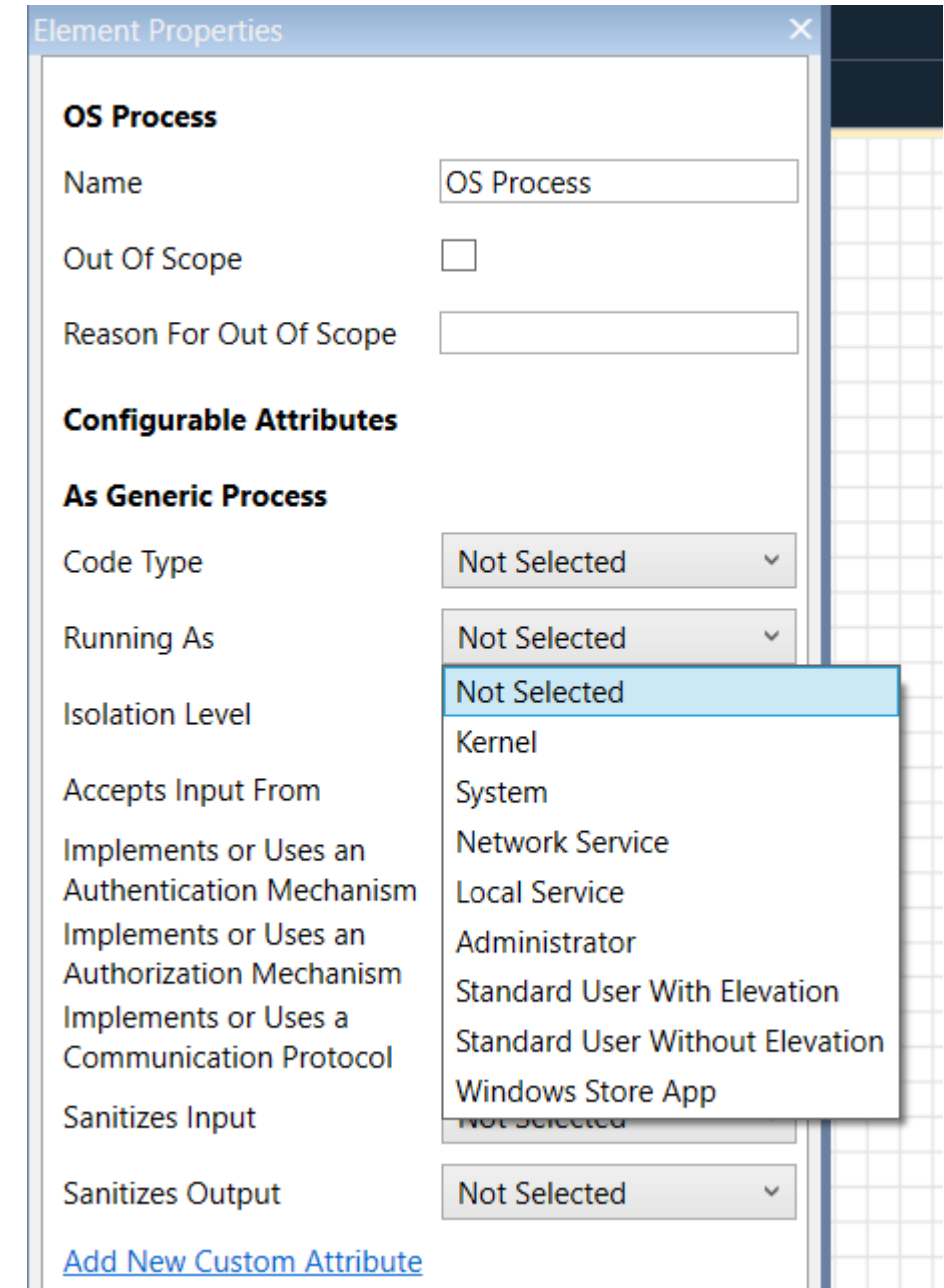
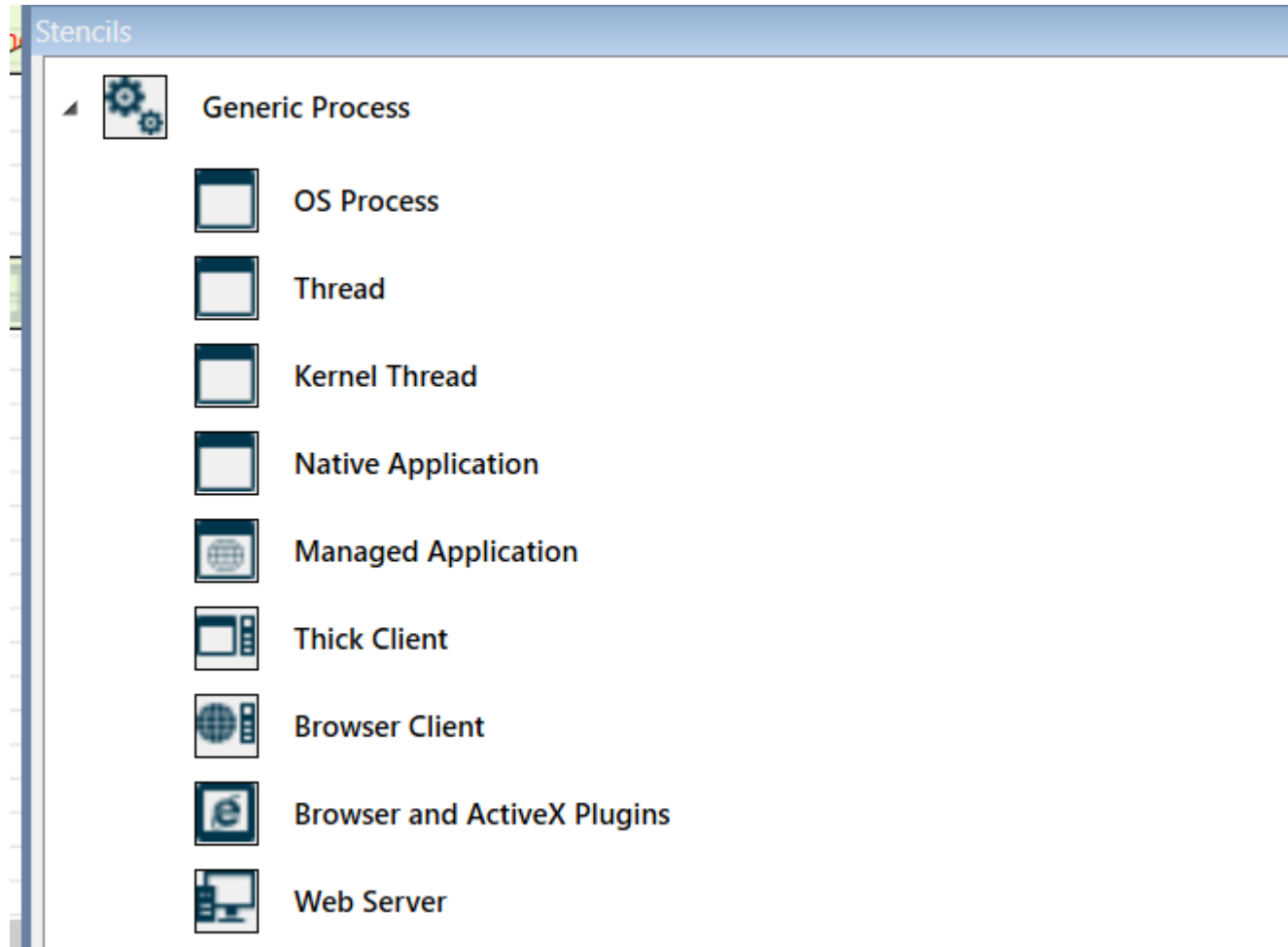
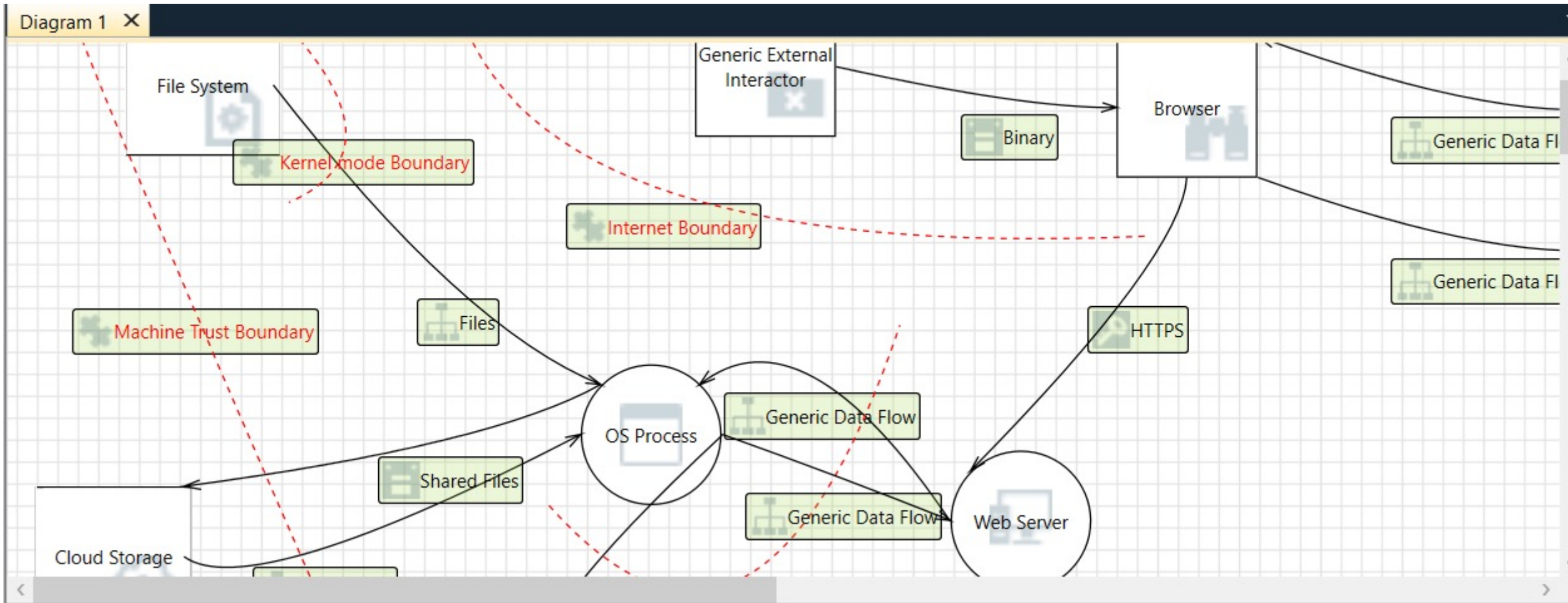


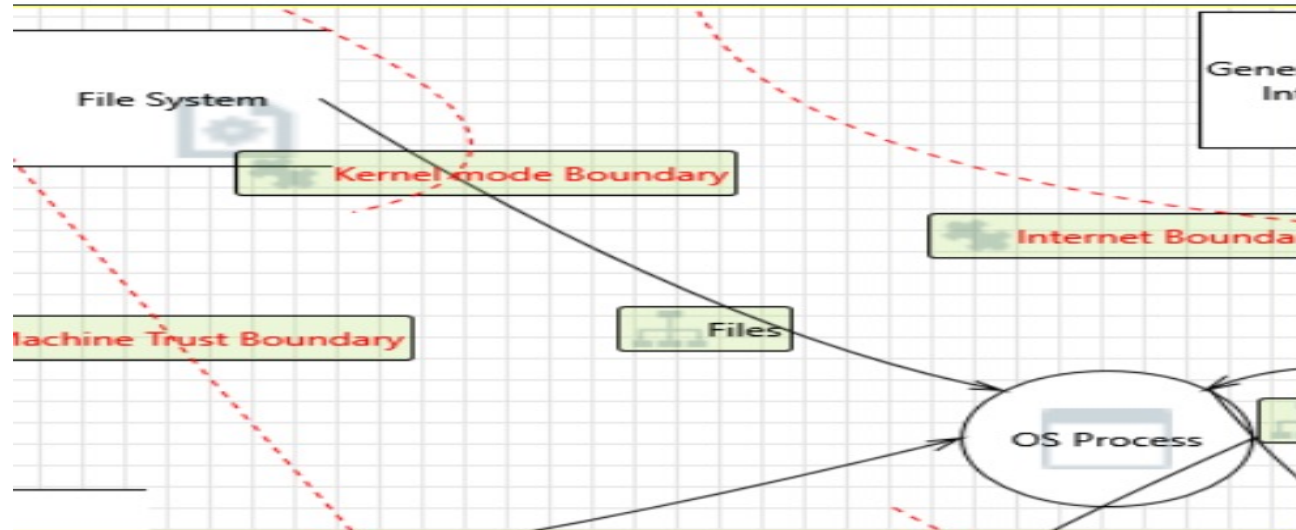
Диаграмма системы: Пример



Анализ угроз

Threat List											
ID	Diagram	Changed By	Last Modified	State	Title	Category	Description	Justification	Interaction	Priority	
40	Diagram 1		Generated	Not Started	Authenticated...	Tampering	An attacker ca...		In Perosn Access	High	
2	Diagram 1		Generated	Not Started	Cross Site Scri...	Tampering	The web serve...		HTTPS	High	
7	Diagram 1		Generated	Not Started	Cross Site Scri...	Tampering	The web serve...		Generic Data F...	High	
4	Diagram 1		Generated	Not Started	Data Flow Files...	Denial Of Servi...	An external ag...		Files	High	
25	Diagram 1		Generated	Not Started	Data Flow Gen...	Denial Of Servi...	An external ag...		Generic Data F...	High	
34	Diagram 1		Generated	Not Started	Data Flow Gen...	Denial Of Servi...	An external ag...		Generic Data F...	High	
16	Diagram 1		Generated	Not Started	Data Flow Pow...	Denial Of Servi...	An external ag...		PowerPoint for...	High	
0	Diagram 1		Generated	Not Started	Data Flow Shar...	Denial Of Servi...	An external ag...		Shared Files	High	
14	Diagram 1		Generated	Not Started	Data Flow Snif...	Information Di...	Data flowing a...		PowerPoint for...	High	
23	Diagram 1		Generated	Not Started	Data Flow Snif...	Information Di...	Data flowing a...		Generic Data F...	High	
32	Diagram 1		Generated	Not Started	Data Flow Snif...	Information Di...	Data flowing a...		Generic Data F...	High	
5	Diagram 1		Generated	Not Started	Data Store Ina...	Denial Of Servi...	An external ag...		Files	High	
1	Diagram 1		Generated	Not Started	Data Store Ina...	Denial Of Servi...	An external ag...		Shared Files	High	
18	Diagram 1		Generated	Not Started	Elevation by C...	Elevation Of Pr...	An attacker m...		PowerPoint for...	High	

Отчет безопасности



Содержит
рекомендации по
устранению угрозы.
Использует базу
знаний

Spoofing of Source Data Store File System [State: Not Started] [Priority: High]

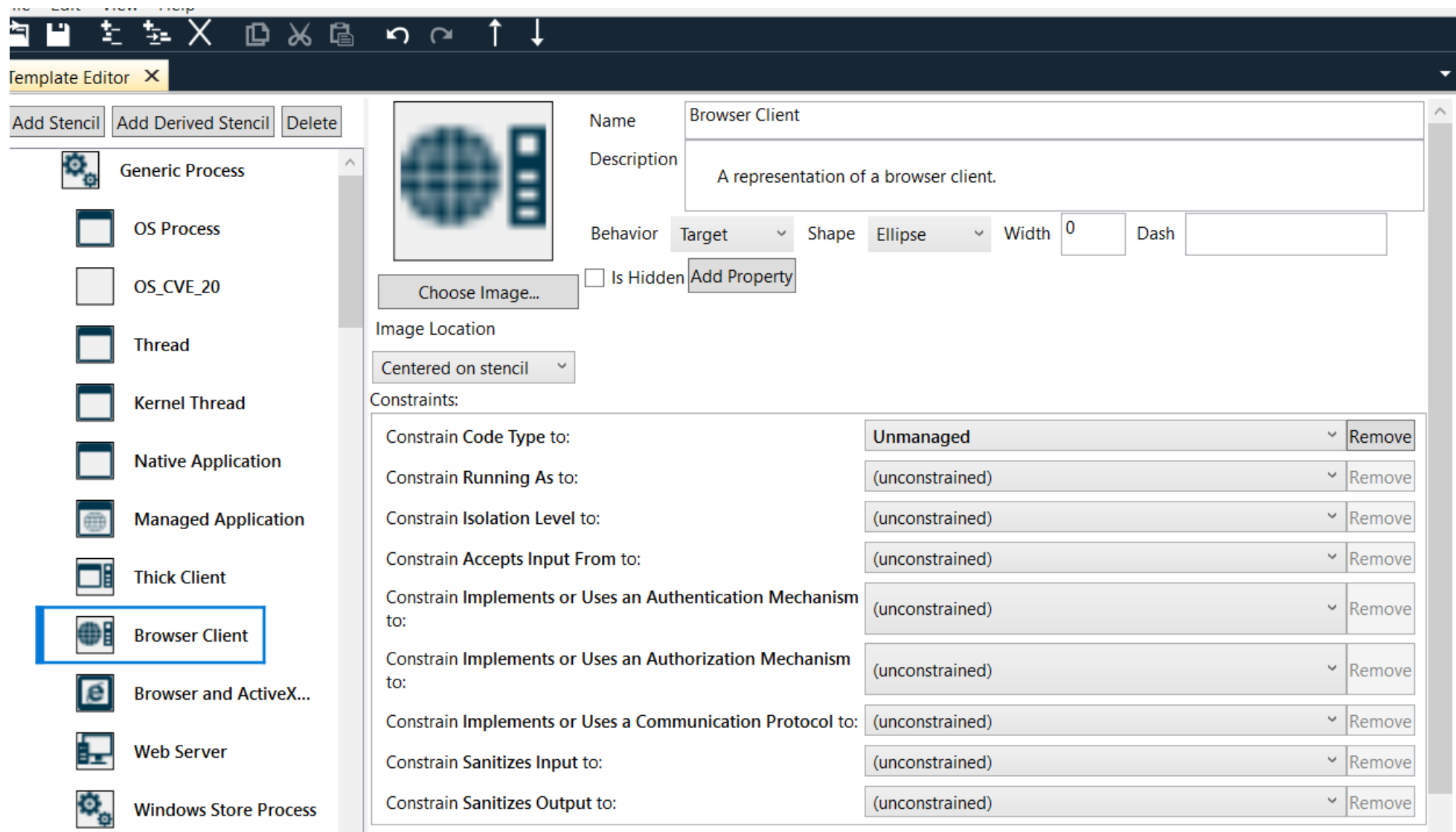
Category: Spoofing

Description: File System may be spoofed by an attacker and this may lead to incorrect data store.

Justification: <no mitigation provided>

Weak Access Control for a Resource [State: Not Started] [Priority: High]

Создать собственный трафарет



Создать собственную угрозу

class_room1* - Threat Modeling Tool 2016

File Edit View Help

Template Editor

New Category New Threat Type Delete

Spoofing

- Spoofing (v3)
- Spoofing the {source.Name} Process**
- Spoofing the {target.Name} Process
- Spoofing the {source.Name} External E...
- Spoofing of Source Data Store {source....
- Spoofing of Destination Data Store {tar...
- Spoofing of the {target.Name} External...

Tampering

- Tampering (v3)
- Potential Lack of Input Validation for {t...
- {source.Name} Process Memory Tampe...

Title: Spoofing the {source.Name} Process

Threat Generation Expressions:

Generation expressions determine when an instance of a threat type gets created for a threat model. An example of generation expression is: flow.[Authenticates Destination] is 'Yes'.

Include: source is [Generic Process] and (target is [Generic Process] or target is [Generic Data Store]) and (flow crosses [Generic Trust Line Boundary] or flow crosses [Generic Trust Border Boundary])

Exclude: flow.[Source Authenticated] is 'Yes' or source.[Implements or Uses an Authentication Mechanism] is 'Yes'

Threat Property Presets: (Enter text that will be included in each instance of the threat that is created in a diagram. You can use macros to refer to elements of the diagram. Threats are always created on flow stencils. Macros can refer to any stencil property of the flow or the source or target of the flow. Use curly braces to insert a macro, for example "Look for issues with the {flow.name} flow". You can also use macros in the threat title.)

Description	{source.Name} may be spoofed by an attacker and this may lead to unauthorized access to {target.Name}. Consider using a standard authentication mechanism to identify the source process.
Justification	
Priority	

Сопоставление уязвимостей MITRE (CVE) и угроз модели STRIDE

От CVE к угрозам STRIDE

- Насколько известно, полного процесса сопоставления CVE со STRIDE не существует. Наиболее эффективный метод основан на соотнесении CVE с CWE и дальнейшем анализе технического воздействия и масштаба влияния CWE в формулировках STRIDE.
- Параллельно в литературе существует несколько методов на основе ИИ для сопоставления CVE с CWE; все они в той или иной степени основаны на обработке текста.
- **Надо учесть что есть сложность правильного сопоставления CVE с CWE [Loveless 2008].**
- Один из используемых на практике (но не идеальный) метод сопоставления CWE (Common Weakness Enumeration) и STRIDE предложен в работе [Honkaranta et al. 2021].

Вспоминаем MITRE (CVE)

- <https://cve.mitre.org>
- База данных общеизвестных уязвимостей CVE это "словарь" известных угроз, каждая запись которого состоит из следующих разделов: CVE ID, Reference, Description.

Вспоминаем CWE

699 - Software Development

-    API / Function Errors - (1228)
-    Audit / Logging Errors - (1210)
-    Authentication Errors - (1211)
-    Authorization Errors - (1212)
-    Bad Coding Practices - (1006)
-    Behavioral Problems - (438)
-    Business Logic Errors - (840)
-    Communication Channel Errors - (1225)
-    Complexity Issues - (1226)

CWE CATEGORY: Authentication Errors

Category ID: 1211

Vulnerability Mapping: **PROHIBITED**

▼ Summary

Weaknesses in this category are related to authentication. The goal is to verify that an entity is indeed who it claims to be. If no weaknesses could lead to a degradation of the quality of the system.

▼ Membership

Nature	Type	ID	Name
MemberOf		699	Software Development
HasMember		289	Authentication Bypass by
HasMember		290	Authentication Bypass by

Наличие признака CWE в CVE (пример ФСТЭК)

?

☐ Доступно расширенное описание ?

Год добавления ?

Выберите год добавления ▼

Класс уязвимости ?

Выберите класс уязвимости ▼

Все идентификаторы

CWE-1

CWE-2

CWE-3

CWE-4

CWE-5

CWE-6

CWE-7

× CWE-762 |

Информация

BDU:2025-16177

Уязвимость реализации режима Org текста редактора EMACS, позволяющая нарушителю оказат целостность и доступность защищаемой и

BDU:2025-16176

Уязвимость реализации языка разметки La редактора EMACS, позволяющая нарушит отказ в обслуживании

BDU:2025-16175

Уязвимость реализации протокола MIME т редактора EMACS, позволяющая нарушит отказ в обслуживании

<<

<

1

2

3

4

5

6

7

8

9

Скачать сведения об уязвимостях в фо

Скачать сведения об уязвимостях в фо

Feature	CWE	CVE
Focus	Software weaknesses (design flaws).	Specific, identified vulnerabilities.
Usage	Proactive development and design.	Reactive vulnerability management.
Audience	Developers, architects, trainers.	Security analysts, incident responders.
Examples	CWE-20 (Improper Input Validation).	CVE-2023-12345 (Specific exploit).

Метод сопоставления CWE и STRIDE

- Для формата CWE :
 - Область действия (Score) CWE: определяет область безопасности приложения, которая нарушена;
 - Техническое воздействие (Technical Impact) CWE: описывает негативное техническое воздействие, если злоумышленнику удастся использовать эту уязвимость.

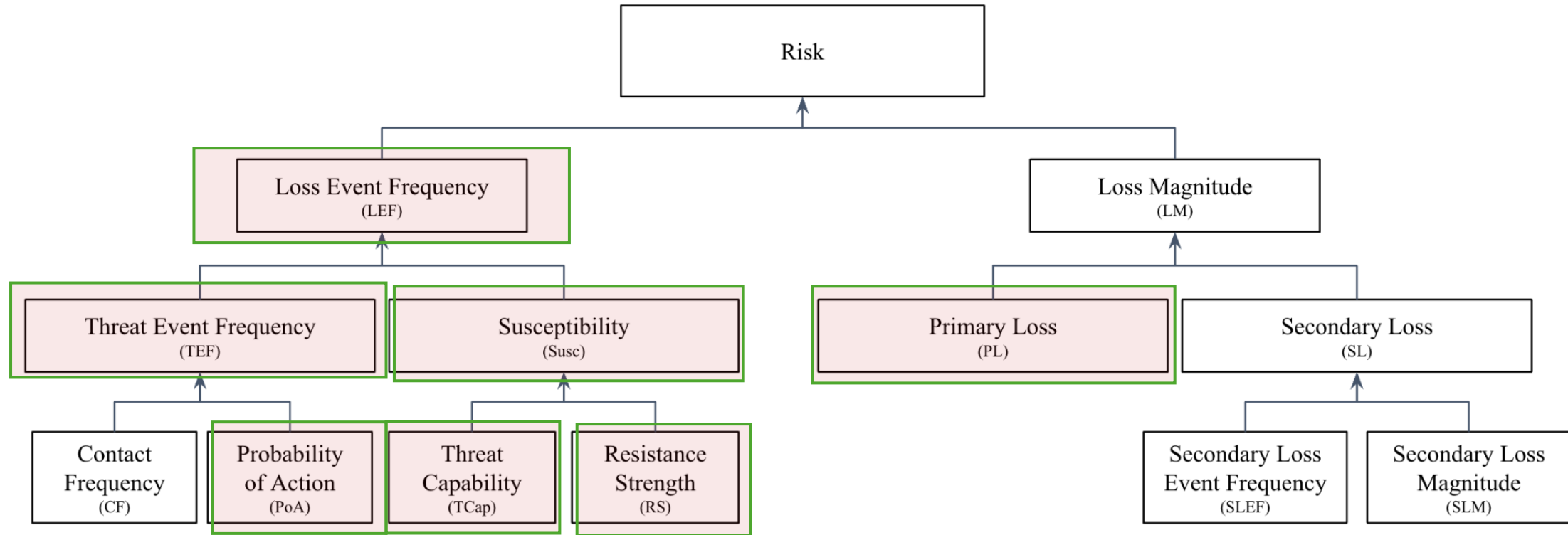
STRIDE	CWE/Technical Impact	CWE/Scope
Spoofing	Gain privileges / Assume identity	Access control - Authentication
Tampering	Modify data	Integrity
Repudiation	Hide activities	Non-Repudiation - Accountability
Information disclosure (privacy breach or data leak)	Read data	Confidentiality
Denial of service	DoS: unreliable execution	Availability
Denial of service	DoS: resource consumption	Availability
Elevation of privilege	Execute unauthorized code or commands	Confidentiality - Integrity - Availability - Access control
Elevation of privilege	Bypass protection mechanism	Access Control - Authentication

Таблица 1. Соответствие CWE и STRIDE [Honkaranta et al. 2021]

CVSS достаточно для оценки риска?

- Модель оценки CVSS включает в себя множество математических вычислений с порядковыми значениями. Функционально это то же самое, что и вычисления с цветовой шкалой [Jack Jones, FAIR™]
- «Для количественного анализа необходима единица измерения — количество чего-либо, например, частота, процент, денежная стоимость, время и т. д. В числовой порядковой шкале (например, от 1 до 5 или от 1 до 10) числа являются просто обозначениями категорий/групп, подобно цветам...
- *The Common Vulnerability Scoring System (CVSS) is a method used to supply a qualitative measure of severity. **CVSS is not a measure of risk.** [https://nvd.nist.gov/vuln-metrics/cvss]*

Модель риска FAIR и CVSS



Два распространенных метода применения CVSS:

- расчет степени серьезности обнаруженных уязвимостей в системах,
- использование в качестве фактора при определении приоритетов мероприятий по устранению уязвимостей.

Как использовать CVSS при оценке риска?

- Следует использовать комплексную систему оценки рисков, учитывающую больше факторов, чем просто базовый балл CVSS. Такие системы, как правило, также учитывают факторы, выходящие за рамки CVSS, например воздействие и угроза

Пример:

- **CVSS Base** (severity anchor)
- **EPSS** (probability of exploitation in the wild)
- **KEV flag** (known to be exploited)
- **Asset criticality** (business service tier, data classification)
- **Exposure** (internet-facing, reachable path, compensating controls)

Порядковая шкала:

- **P1**: KEV-listed on internet-facing tier-1 asset, or EPSS ≥ 0.7 with high criticality.
- **P2**: CVSS base ≥ 8.0 with EPSS ≥ 0.2 or exposed lateral path on tier-1/2 assets.
- **P3**: All others; batch and schedule per maintenance windows.

Пример оценки риска для CVE

Пример (уязвимость компьютера в лекционном зале)

- Уязвимость исполняемого файла iscsicpl.exe операционной системы Windows связана с возможностью подмены dll-файла. Эксплуатация уязвимости может позволить нарушителю выполнить произвольный код **BDU:2022-06631**
<https://bdu.fstec.ru/vul/2022-06631>
- На компьютере установлена MS Windows и он подключён к сети

Вектор CVSS v3: (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

Базовые метрики ? **9.8** AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Базовая оценка (BS): 9.8

Вектор атаки (AV):

Сетевой (N)	Смежная сеть (A)	Локальный (L)	Физический (P)
--------------------	------------------	---------------	----------------

Сложность атаки (AC):

Высокая (H)	Низкая (L)
-------------	-------------------

Уровень привилегий (PR):

Высокий (H)	Низкий (L)	Не требуется (N)
-------------	------------	-------------------------

Взаимодействие с пользователем (UI):

Требуется (R)	Не требуется (N)
---------------	-------------------------

Влияние на другие компоненты системы (S):

Не оказывает (U)	Оказывает (C)
-------------------------	---------------

Влияние на конфиденциальность (C):

Не оказывает (N)	Низкое (L)	Высокое (H)
------------------	------------	--------------------

Влияние на целостность (I):

Не оказывает (N)	Низкое (L)	Высокое (H)
------------------	------------	--------------------

Влияние на доступность (A):

Не оказывает (N)	Низкое (L)	Высокое (H)
------------------	------------	--------------------

Модель угроз: Уровень нарушителя

- В зависимости от уровня возможностей нарушители подразделяются на нарушителей, обладающих:
- базовыми возможностями по реализации угроз безопасности информации (Н1);
- базовыми повышенными возможностями по реализации угроз безопасности информации (Н2);
- средними возможностями по реализации угроз безопасности информации (Н3);
- высокими возможностями по реализации угроз безопасности информации (Н4).

Подробнее: Приложение 8 к Методике оценки угроз безопасности информации ФСТЭК

Продолжение: BDU:2022-06631

• **CWE-427: Uncontrolled Search Path Element**

	Impact	Details
	<i>Execute Unauthorized Code or Commands</i>	Scope: Confidentiality, Integrity, Availability

См. Таблицу 1

Elevation of privilege	Execute unauthorized code or commands	Confidentiality - Integrity - Availability Access control
Elevation of privilege	Bypass protection mechanism	Access Control - Authentication

Новая угроза в MTMT для учета CVE

Title: CVE generic elevation privelege BDU:2022-06631

Expressions:

Generation expressions determine when an instance of a threat type gets created for a threat model. An example of generation expression is: flow.[Authenticates Destination] i

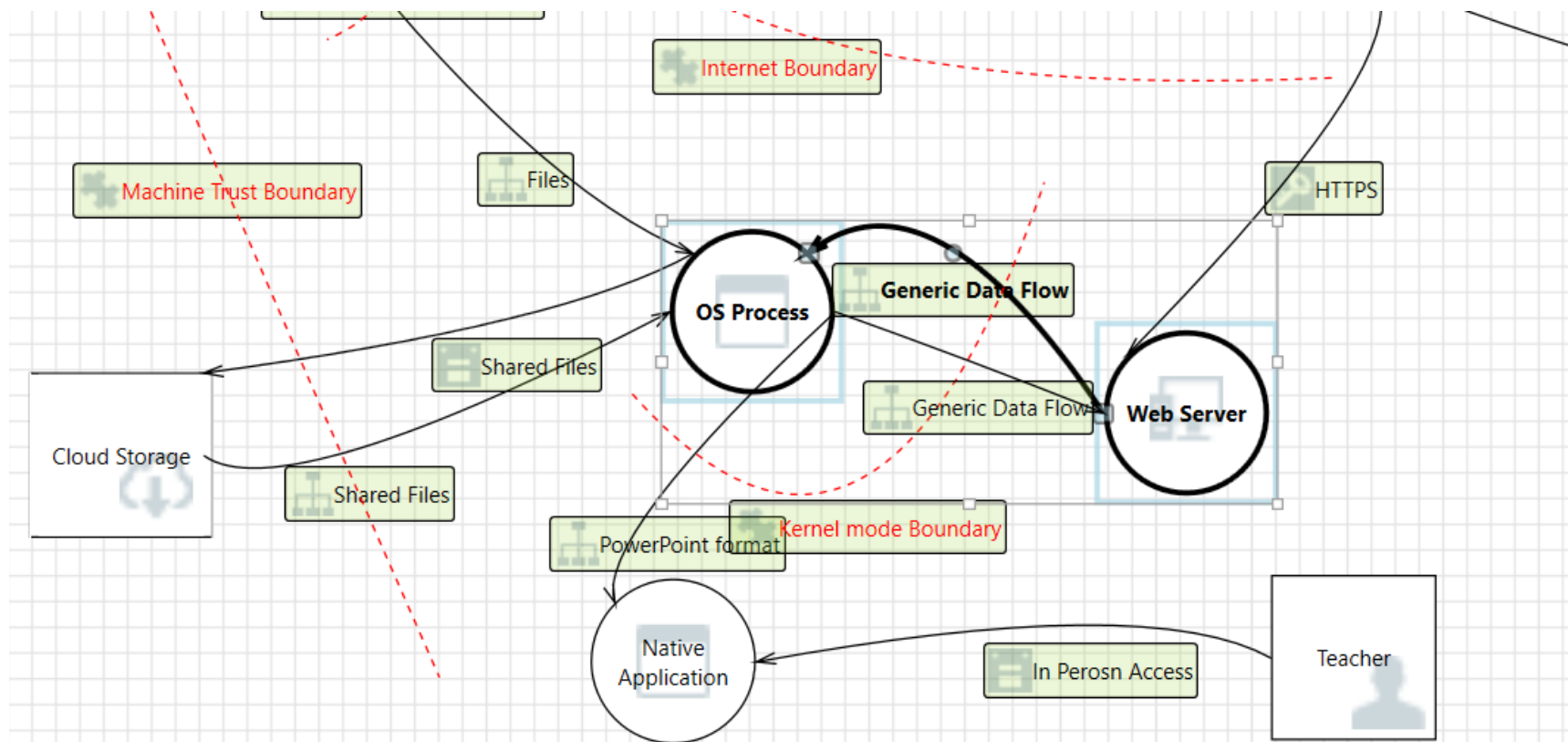
clude: source is [Web server] and flow crosses [User mode or Kernel mode Boundary]

clude:

esets: (Enter text that will be included in each instance of the threat that is created in a diagram. You can use macros to refer to elements of the diagram. Threats are always created c refer to any stencil property of the flow or the source or target of the flow. Use curly braces to insert a macro, for example "Look for issues with the {flow.name} flow". You can i title.)

Description	Уязвимость исполняемого файла iscsicpl.exe операционной системы Windows связана с возможностью подмены dll-файла. Это может позволить нарушителю выполнить произвольный код
Justification	https://github.com/hackerhouse-opensource/iscsicpl_bypassUAC
Priority	Medium

Применение МТМТ для учета CVE



Threat List

ID	Diagram	Changed By	Last Modified	State	Title	Category	Description	Justification
166	Diagram 1		Generated	Not Started	CVE generic el...	Elevation Of Pr...	Уязвимость и...	https://github....
167	Diagram 1		Generated	Not Started	CVE generic el...	Elevation Of Pr...	Уязвимость и...	https://github....
170	Diagram 1		Generated	Not Started	CVE generic el...	Elevation Of Pr...	Уязвимость и...	https://github....

STRIDE и БД Угроз ФСТЭК

- Подмена личности (**Spoofing** identity)
- Подделка данных (**Tampering** with data)
- Угрозы отказа в совершении действия (**Repudiation** threats)
- Раскрытие информации (**Information** disclosure)
- Отказ в обслуживании (**Denial** of service)
- Повышение привилегий (**Elevation** of privileges)
- УБИ 128 Угроза подмены доверенного пользователя
- УБИ 042 подделки запроса
- ?
- УБИ 203 Угроза утечки информации с неподключенных к сети Интернет компьютеров
- УБИ 140 отказ в обслуживании
- УБИ 122 превышение привилегии

Дополнение: Таксономия атак (MITRE CAPEC)

- Common Attack Pattern Enumeration and Classification (CAPEC). <https://capec.mitre.org>, реализует иерархический подход и представлены два основных представления атак:
- В представлении «**механизмы атаки**» шаблоны иерархически упорядочены в соответствии с механизмами, которые часто используются при эксплуатации уязвимостей. Категории, например «внедрение непредвиденных элементов», в этом представлении отражают различные методы, используемые для атаки на систему, но не отображают целей и последствий.
- В представлении «**домены атаки**» категории содержат описание компонентов, на которые производится атака, например «передача данных».